

Guía de Remediación Técnica NOVASHOP

Responsable: Maria M. Segura Hernández

Proyecto: Fortalecimiento de Infraestructura NOVASHOP

Marco de Referencia: ISO/IEC 27001 (A.8.12 Seguridad de redes)/ ISO/IEC 27005

Departamento Destino: Infraestructura y Operaciones

Resumen de Alineación de Activos

Antes de proceder a dar los procedimientos técnicos , se confirma la identificación de los activos críticos sobre los cuales se va a aplicar los controles de seguridad:

ID Activo	Componente Técnico	Función Crítica
ID-01	Cisco Catalyst 9500 (Stack)	Núcleo de Red (Core) y Enrutamiento Inter-VLAN.
ID-02	Cisco Catalyst 9200 (10 unidades)	Conectividad de acceso para usuarios y dispositivos.
ID-03	Dell PowerEdge R450 (3 unidades)	Hosting de SGBD SQL Server y Aplicaciones.
ID-04	Cisco IP Phone 8841 / UPS APC	Comunicaciones de Voz y Resiliencia Eléctrica.
ID-05	Rack 42U / Cámaras Meraki MV	Infraestructura Física y Videovigilancia.
ID-06	Cisco Firepower (NGFW)	Seguridad Perimetral, VPN y Control DMZ.

GUÍA TÉCNICA DE EJECUCIÓN

A Continuación voy a desarrollar un paso a paso de las estrategias de mitigación para cada activo de la red.

Estrategia de mitigación de la infraestructura central

Campo	Detalle
ID Vulnerabilidad	R1 - Punto Único de Falla (SPOF) en la Infraestructura Central
Activo Crítico	Core Switch Cisco Catalyst 9500 (ID-01) y Servidores (ID-03)
Impacto de Riesgo	Crítico: Cese total de operaciones (Ventas en la aplicación y sede física)
Estrategia	Alta Disponibilidad mediante StackWise-480 y redundancia LACP

Solución: Implementación de StackWise-480

Paso 1: Configuración de Apilamiento (Stacking) Conecte físicamente el segundo Catalyst 9500.

Paso 2: Por medio de protocolos de redundancia de primer asalto (FHRP), configure la prioridad para que el switch antiguo esté activo y el nuevo switch esté en espera .

```
# En el Switch Principal (Existente)
(config)# switch 1 priority 15

# En el Switch Secundario (Nuevo)
(config)# switch 2 priority 1
```

Resultado: En caso de fallo del switch principal, el secundario toma el control en milisegundos, manteniendo la continuidad del servicio sin afectar al usuario final.

Agregación de Enlaces (LACP) para Servidores Dell PowerEdge R450

Para que los servidores Dell PowerEdge R450 (que alojan la aplicación de ventas) no queden aislados si uno de los switches del stack falla, se utiliza la agregación de enlaces distribuida.

Configuración de EtherChannel Distribuido

Al usar el rango 1/0/1 (Switch 1) y 2/0/1 (Switch 2), garantizamos que el servidor tenga un pie en cada chasis físico.

```
# Configuración de interfaces físicas distribuidas
(config)# interface range GigabitEthernet1/0/1, GigabitEthernet2/0/1
(config-if-range)# description Enlace Redundante Servidor Dell R450 (LACP)
(config-if-range)# channel-protocol lacp
(config-if-range)# channel-group 1 mode active

# Configuración de la interfaz lógica (Port-Channel)
(config)# interface port-channel 1
(config-if)# description Interface Lógica hacia Servidor R450
(config-if)# switchport mode access
(config-if)# switchport access vlan 110
(config-if)# spanning-tree portfast
```

Nota técnica: El uso de spanning-tree portfast en el Port-Channel es crítico para que el servidor obtenga conectividad inmediata tras un reinicio, evitando los estados de bloqueo de STP.

Resultados Esperados y Verificación

- Continuidad de Negocio: La conmutación por error (failover) ocurre en milisegundos, imperceptible para las transacciones de la aplicación.
- Ancho de Banda: Se duplica el rendimiento hacia el servidor (2Gbps si ambos enlaces son de 1Gbps).

Comandos de Verificación:

- show switch: Para verificar que ambos miembros están ready en el stack.

- show etherchannel summary: Para confirmar que el Port-Channel 1 está en estado (P) en ambos switches.

Recomendación Adicional

Para cerrar el ciclo de robustecimiento, asegúrate de que cada switch esté conectado a una fuente de alimentación (PDU) distinta. De nada sirve tener dos switches si ambos dependen de un solo regulador o UPS que pueda fallar. También validar la opción de tener un sistema eléctrico adicional como generadores o servicios secundarios de alimentación eléctrica.

Estrategia de mitigación de Seguridad de Capa 2

Campo	Detalle
ID Vulnerabilidad	R4 - Suplantación de Identidad y R6- Ataque de Resolución de Nombres DNS
Activo Crítico	Switches Catalyst 9200 (ID-02) y Teléfonos Cisco 8841 (ID-04)
Impacto de Riesgo	Alto: Intercepción de credenciales (Man-in-the-Middle) , acceso no autorizado, escucha de telefonía IP..
Estrategia	Endurecimiento (DHCP Snooping/DAI), DNSSEC ,Seguridad Inalámbrica y Segmentación de VLAN de Voz y QoS.

Endurecimiento (Hardening) de Capa de Acceso

Paso 1: Implementación de DHCP Snooping y DAI

El objetivo es crear una base de datos de confianza en el switch que impida que dispositivos no autorizados asignen direcciones IP o manipulen las tablas ARP de otros usuarios. Es fundamental definir qué puerto es la fuente legítima de identidad (normalmente el enlace hacia el Core o el servidor DHCP)

```
# Habilitar DHCP Snooping de forma global y para las VLANs operativas
(config)# ip dhcp snooping
(config)# ip dhcp snooping vlan 10,20,110

# Habilitar Dynamic ARP Inspection (DAI) para evitar el ARP Poisoning
(config)# ip arp inspection vlan 10,20,110

# Configurar el Uplink hacia el Core como "Puerto de Confianza"
# Sin esto, el switch bloqueará incluso las respuestas legítimas del servidor DHCP
(config)# interface TenGigabitEthernet1/0/1
(config-if)# description Enlace de Confianza hacia Core Catalyst 9300
(config-if)# ip dhcp snooping trust
(config-if)# ip arp inspection trust
```

Paso 2: Segmentación y seguridad de puerto

Para mitigar la falta de segmentación, se debe asegurar que cada puerto de usuario pertenezca a la VLAN correcta y que no se puedan conectar dispositivos aleatorios.

```
# Aplicar a los puertos de acceso (ejemplo: PCs, teléfonos)
(config)# interface range GigabitEthernet1/0/2-24
(config-if)# switchport mode access
(config-if)# switchport access vlan 10
(config-if)# spanning-tree portfast
(config-if)# spanning-tree bpduguard enable

# Opcional: Limitar el número de direcciones MAC (Port Security)
(config-if)# switchport port-security
(config-if)# switchport port-security maximum 2
(config-if)# switchport port-security violation restrict
```

Nota técnica : El comando `bpduguard` protege la red de bucles accidentales si alguien conecta un switch no autorizado en los cubículos de la sede física.

Paso 3: Segmentación de Voz y Calidad de Servicio (QoS)

Aislar el tráfico de telefonía IP para evitar la interceptación de llamadas mediante técnicas de sniffing en el segmento de datos y garantizar la prioridad de la voz sobre el tráfico de red común.

Configuración de VLAN de Voz y Acceso

Se definen las VLANs específicas para separar lógicamente los dominios de colisión y difusión.

```
# Definición de la VLAN de Voz
(config)# vlan 20
(config-vlan)# name VOZ_IP_CRITICA

# Configuración de interfaces de usuario (Smartport)
# Permite que un PC y un teléfono Cisco compartan el mismo puerto de forma segura
(config)# interface range GigabitEthernet1/0/2-24
(config-if)# switchport mode access
(config-if)# switchport access vlan 10          # VLAN de Datos
(config-if)# switchport voice vlan 20          # VLAN de Voz (Aislamiento)
(config-if)# spanning-tree portfast
```

Nota técnica : Se separa el tráfico de los teléfonos ID-04 en una VLAN de Voz con prioridad **QoS**, impidiendo que el segmento de datos (VLAN 10) pueda escuchar el tráfico RTP.

Paso 3: Defensa Perímetro DNS (DNSSEC)

Firma digital de la zona novashop.com para evitar el envenenamiento DNS y redireccionamiento de usuarios.

```
# 1. Generar la Llave de Firma de Zona (ZSK)
dnssec-keygen -a RSASHA256 -b 2048 -n ZONE novashop.com

# 2. Generar la Llave de Firma de Llaves (KSK)
dnssec-keygen -a RSASHA256 -b 4096 -f KSK -n ZONE novashop.com

# 3. Firmar la zona para generar los registros RRSIG y DNSKEY
dnssec-signzone -o novashop.com -k KSK_FILE ZONE_FILE ZSK_FILE

# 4. Verificación desde el terminal del Tester:
# El flag "ad" (Authenticated Data) confirma que DNSSEC está activo.
dig @192.168.10.10 ventas.novashop.com +dnssec
```

Paso 4: Seguridad Inalámbrica (VLAN 100)

Aislamiento de puntos de acceso para que los clientes Wi-Fi no se comuniquen entre sí y uso de WPA 3 / 802.1 para asegurar que solo dispositivos corporativos se conecten.

```
# Crear ACL para bloquear tráfico Wi-Fi hacia Servidores
(config)# ip access-list extended RESTRICCION_WIFI
(config-ext-nacl)# deny ip 192.168.100.0 0.0.0.255 192.168.110.0 0.0.0.255
(config-ext-nacl)# permit ip 192.168.100.0 0.0.0.255 any

# Aplicar a la interfaz de la VLAN 100
(config)# interface vlan 100
(config-if)# ip access-group RESTRICCION_WIFI in
```

Resultados Esperados y Verificación

- Prevención MitM: Cualquier intento de un atacante de enviar un *ARP Reply* falso será descartado por el switch al no coincidir con la base de datos de DHCP Snooping.
- Prueba de Sniffing: Cualquier intento de capturar paquetes RTP (voz) desde la VLAN 10; el tráfico de voz resultó invisible para el segmento de datos.
- Aislamiento de Tráfico: Los usuarios de la VLAN 10 no pueden ver el tráfico de servidores (VLAN 110) ni de voz (VLAN 20) sin pasar por el Firewall/Core con ACLs
- Validación DNS: Navegadores verifican la IP legítima de NOVASHOP.

Comandos de Verificación:

- show ip dhcp snooping binding: Lista de dispositivos legales conocidos.
- show ip arp inspection statistics: Conteo de paquetes ARP maliciosos bloqueados.
- show interfaces switchport: Confirma que el puerto opera con Access VLAN y Voice VLAN de forma aislada.
- show mls qos interface: Verifica el etiquetado correcto de los paquetes de los teléfonos Cisco 8841 para evitar latencia.

Recomendación Adicional

Dado que esta configuración depende de la tabla de ARP si realizas cambios manuales de direcciones IP (IPs estáticas) en los servidores, recuerda configurar ARP Access Lists o registros estáticos en el switch para evitar que el DAI bloquee accidentalmente a un servidor legítimo.

Estrategia de mitigación de cifrado de gestión y control de acceso

Campo	Detalle
ID Vulnerabilidad	R5 - Protocolos Inseguros y R2 - Movimiento Lateral
Activo Crítico	Toda la Infraestructura (Core/Acceso) y Servidores Dell (ID-04)
Impacto de Riesgo	Medio-Alto: Captura de credenciales en texto plano y propagación de ataques entre servidores.
Estrategia	Endurecimiento de la gestión mediante SSH/HTTPS y micro-segmentación con ACLs extendidas ,MFA y WAF.

Gestión Segura y Listas de Control de Acceso (ACL)

Paso 1: Desactivación de Protocolos Inseguros y MFA (RADIUS)

El objetivo es garantizar que cualquier sesión administrativa viaje cifrada, evitando que un atacante con un sniffer de red (como Wireshark) capture contraseñas de administración y centralizamos la autenticación para habilitar el segundo factor.

```
# Desactivación de protocolos inseguros
(config)# no ip http server
(config)# ip ssh version 2

# ACL de Gestión: Solo permite acceso desde subred de administradores
(config)# ip access-list standard ACL-ADMIN-ONLY
(config-std-nacl)# permit 192.168.99.0 0.0.0.255

# Configuración de Servidor RADIUS para MFA
(config)# radius-server host 192.168.99.50 key NOVASHOP_KEY
(config)# aaa authentication login default group radius local
```

Paso 2: Microsegmentación SQL (Puerto 1433) y WAF

Para proteger la integridad de los datos de la empresa, se aplica el principio de menor privilegio, permitiendo que solo el servidor de aplicaciones acceda a la base de datos de producción.

Implementación de ACL Extendida en VLAN 110

Esta configuración detiene el movimiento lateral (por ejemplo, si una PC de la oficina es comprometida, no podrá atacar directamente la base de datos). En el firewall firepower se define la regla para que solo la ip del servidor web hable con el SQL server.

```
# Definición de la lista de acceso para el servidor de base de datos
(config)# ip access-list extended FW-SQL-SERVER
(config-ext-nacl)# remark Permitir trafico SQL solo desde Servidor App
(config-ext-nacl)# permit tcp host 192.168.110.10 host 192.168.110.20 eq 1433
(config-ext-nacl)# remark Denegar cualquier otro acceso a la base de datos
(config-ext-nacl)# deny ip any host 192.168.110.20
(config-ext-nacl)# remark Permitir el resto del trafico de la VLAN
(config-ext-nacl)# permit ip any any

# Aplicación de la ACL en la interfaz virtual (SVI) correspondiente
(config)# interface vlan 110
(config-if)# ip access-group FW-SQL-SERVER in
```

Paso 3: WAF (Firewall de Aplicaciones Web): Activación en el borde de la DMZ para bloquear patrones de inyección SQL antes de llegar a la tienda virtual.

```
# Regla de detección de firmas SQLi
IF (HTTP_REQUEST_PARAMETERS contains ["'", "--", "OR", "SELECT", "DROP", "UNION"])
THEN
    ACTION: BLOCK_REQUEST
    LOG: "Intento de SQL Injection detectado desde IP: $REMOTE_ADDR"
    RESPONSE: 403 Forbidden
END IF
```

Para que puedas comprobar si los comandos anteriores están funcionando, una vez aplicados, debes ejecutar este script rápido desde alguna de las estaciones de trabajo del sector de operaciones.

```
# Intentar conectar al SQL desde una red no autorizada
# El resultado esperado es "Connection timed out" o "Connection refused"
nc -zv -w 5 192.168.110.100 1433

# Si el comando anterior falla, la segmentación es EXITOSA.
```

Resultados Esperados y Verificación

- Gestión Blindada: Intentos de conexión vía Telnet o HTTP serán rechazados automáticamente por los dispositivos.
- Micro-segmentación: El activo más crítico (Base de Datos) queda invisible para el resto de la red, excepto para su aplicación autorizada.

Comandos de Verificación:

- show ip ssh: Para confirmar que la versión 2 está activa.
- show access-lists FW-SQL-SERVER: Para observar los contadores y verificar que el tráfico está siendo filtrado correctamente.

Recomendación Adicional

Para un control aún más estricto, se sugiere implementar ACLs de Gestión (VTY ACLs). Esto limitaría el acceso SSH únicamente desde la dirección IP de tu estación de trabajo o desde una

VLAN de administración específica, bloqueando intentos de acceso incluso si el atacante consigue las credenciales.

Estrategia de Mitigación de resiliencia física y monitoreo proactivo

Campo	Detalle
ID Vulnerabilidad	R7 - Seguridad Física y Resiliencia Energética
Activo Crítico	Rack 42U (ID-05), UPS APC (ID-06) y Servidores Dell (ID-04)
Impacto de Riesgo	Crítico: Corrupción de datos por calor/apagado repentino y sabotaje físico.
Estrategia	Monitoreo inteligente (Meraki), sensores SNMP (PRTG) y automatización de apagado.

Implementación de Monitoreo y Continuidad

El objetivo es garantizar que la infraestructura sea capaz de reaccionar automáticamente ante eventos externos que pongan en peligro la integridad del hardware.

Seguridad Física

Se establece un perímetro digital mediante analítica de video para evitar la manipulación del activo.

- Motion Search: Cuadrante digital sobre las puertas del Rack 42U y paneles de UPS.
- Alertas: Notificaciones vía Webhook al equipo de seguridad ante aperturas no autorizadas.
- Retención: Grabación en 1080p con 30 días de respaldo en la nube para trazabilidad forense.

Sensores SNMP y Gestión de Red (PRTG)

Configuración de telemetría para la detección temprana de anomalías térmicas y de tráfico.

- Umbrales Térmicos: Advertencia (26°C): Notificación para revisión de sistemas de enfriamiento. Crítico (30°C): Disparo automático del protocolo de apagado preventivo.
- Defensa DoS (Netstat): Alerta ante picos de >300 conexiones simultáneas hacia el servidor de ventas para mitigar ataques de denegación de servicio.

Script Lógico de Apagado Automatizado

Ante fallos críticos de energía o temperatura, se ejecuta una secuencia de cierre ordenado para proteger la base de datos SQL y el host de virtualización.


```
# Script de remediación automática ante emergencia (Lógica Bash)
# Ejecutado por el software de gestión de UPS o servidor de monitoreo

if [ $UPS_STATUS == "ON_BATTERY" ] && [ $BATTERY_LEVEL -lt 15 ]; then
    echo "Nivel de batería crítico (15%). Iniciando protección de datos..."

    # Cerrar primero servicios de base de datos para evitar corrupción
    ssh admin@sql-server "sudo systemctl stop mssql-server && shutdown -h now"

    # Tiempo de espera para asegurar el cierre de procesos
    sleep 30

    # Apagado del Host físico Dell PowerEdge R450
    echo "Apagando Host de Virtualización..."
    poweroff
```

Validación Técnica

- Prueba de Perímetro: Verificación de la recepción de alertas en el Dashboard de Meraki tras simular una apertura física del rack.
- Prueba de Carga y Failover: Simulación de corte eléctrico para validar que el software PowerChute Network Shutdown inicia el cierre de sesiones en el SQL Server de forma exitosa antes de agotar la reserva de la UPS.
- Simulación SNMP: Forzado de lectura de temperatura de 31°C para verificar la ejecución del script de advertencia en la consola de administración.

Resultados Esperados

- Integridad de Datos: Eliminación del riesgo de bases de datos corruptas por cortes de energía.
- Trazabilidad: Registro visual de cada persona que interactúa físicamente con el Core Switch o los Servidores.
- Respuesta Proactiva: Reducción del tiempo de respuesta ante ataques DoS mediante alertas de conexiones concurrentes.

Configuración de Syslog Centralizado

Objetivo: Garantizar que los eventos de seguridad (bloqueos de WAF, ataques de ARP detectados por DAI y accesos administrativos) se almacenen en un servidor externo inmutable para fines de auditoría forense.

Configuración en la Infraestructura de Red (Cisco Catalyst)

Se configuran los switches para enviar alertas de nivel I 6 o superior al servidor Syslog.

```
# Definir la IP del servidor Syslog centralizado (Sector TI)
(config)# logging host 192.168.99.50

# Configurar el nivel de severidad para capturar bloqueos de DAI y ACLs
(config)# logging trap informational
(config)# logging facility local7

# Asegurar que cada log tenga la estampa de tiempo precisa para correlación
(config)# service timestamps log datetime msec show-timezone
```

Configuración para DAI (Dynamic ARP Inspection)

Para que los intentos de suplantación de identidad queden registrados externamente:

```
# Generar logs cuando DAI bloquee un paquete sospechoso
(config)# ip arp inspection log-buffer entries 1024
(config)# ip arp inspection log-buffer logs 10 interval 10
```

Configuración en el WAF e IPS (Firepower)

En la consola de gestión del Firewall, se activan los registros de flujo hacia el Syslog para cada regla de protección de la tienda virtual:

- Acción: Syslog Logging -> Enabled.
- Evento: Log at Beginning and End of Connection.
- Servidor Destino: 192.168.99.50

Validación Técnica

Para certificar la integridad del sistema de registros, lo puede hacer mediante la siguiente pruebas:

- Generación de Evento: Se puede realizar un intento de acceso SSH fallido y una prueba de inyección de caracteres en el WAF.
- Verificación Local: Se revisa el buffer local del switch con el comando : show logging.
- Verificación Externa: Se accede al servidor Syslog (192.168.99.50) y se confirma que el mensaje ingresó con la dirección IP de origen, la hora exacta y la descripción del bloqueo.

Resultado Esperado

Los registros están protegidos contra el borrado local (clear logging), ya que la copia externa permanece intacta para el equipo de respuesta a incidentes.

Tabla Comparativa de la mejora de red

En esta tabla se puede evidenciar el plan de mitigación para cada hallazgo encontrado en la infraestructura de NOVASHOP

Activos	Hallazgo Inicial (Riesgo)	Control Implementado	Nivel de Riesgo Final
ID-01 Switch Core 1 Catalyst 9500	Punto Único de Falla (SPOF)	StackWise-480 + LACP Distribuido	Bajo (Resiliente)
ID-04 SGBD NovaShop (SQL Server)	Movimiento Lateral (Puerto 1433)	Microsegmentación + Reglas Firepower	Mitigado

ID-01 / ID-03 Gestión de Red (VTY)	Texto plano (Telnet) / Sin MFA	SSH v2 + MFA (RADIUS)	Seguro
ID-05 Telefonía IP (Cisco 8841)	Intercepción MitM (ARP Spoofing)	VLAN de Voz + DHCP Snooping + DAI	Mitigado
ID-04 Aplicación de Ventas Web	Inyección SQL (SQLi)	WAF + Consultas Parametrizadas	Bajo
ID-07 Servicio DNS Interno	Envenenamiento de Caché	Implementación de DNSSEC	Controlado
ID-05 / ID-06 Entorno Físico (Rack 42U)	Estrés Térmico y Autonomía Crítica	PRTG + PowerChute (Shutdown)	Resiliente

Remediación y Fortalecimiento Post-Pentesting

Objetivo

Esta sección documenta las acciones técnicas ejecutadas para neutralizar los vectores de ataque confirmados durante la fase de explotación. Se enfoca en resolver la inyección SQL, el movimiento lateral y la vulnerabilidad de suplantación (ARP Spoofing) mediante controles de defensa en profundidad.

Matriz de Remediación Técnica

Esta tabla cruza los hallazgos críticos del Pentesting con las soluciones finales aplicadas por el equipo técnico:

Hallazgo Confirmado	Activo Afectado	Control de Mitigación Aplicado	Estado Post-Prueba
Inyección SQL (Crítico)	ID-04 Aplicación Web	WAF + Consultas Parametrizadas (PDO)	Mitigado
Movimiento Lateral (SSH)	ID-03 Servidor / ID-01 Core Catalyst 9500	Microsegmentación (ACLs) + MFA	Bloqueado
ARP Spoofing / MITM	ID-02 Acceso / ID-04 Voz	DHCP Snooping + Dynamic ARP Inspection	Protegido
Punto Único de Falla	ID-01 Core Catalyst 9500	Redundancia Física (StackWise-480)	Resiliente
Amenazas Globales	Perímetro Firepower	Inteligencia Cisco Talos	Proactivo

Ejecución Técnica de Remediación

Mitigación de Inyección SQL y Exposición de Datos

Para neutralizar el vector de entrada identificado en el panel administrativo, se implementó:

- Capa de Aplicación: Migración de consultas SQL dinámicas a Sentencias Preparadas. Esto asegura que el *payload* OR 1=1 -- sea tratado como texto plano y no como código ejecutable.
- Capa Perimetral (WAF): Configuración de firmas de inspección profunda en el Cisco Firepower para bloquear intentos de inyección en el puerto 443 antes de que lleguen al servidor web.

Pasos de Remediación Técnica

Paso 1: Mitigación de la Entrada por Aplicación (SQLi)

Para este paso, el equipo de TI debe actuar en dos frentes: el código del servidor y el Firewall perimetral.

- En el Servidor (PHP/MySQL): Se deben reemplazar las consultas manuales por sentencias preparadas para que el motor de base de datos no ejecute el código malicioso.

```
/* Ejemplo de código corregido con PDO para evitar SQLi */
$stmt = $pdo->prepare('SELECT * FROM usuarios WHERE user = :user AND pass = :pass');
$stmt->execute(['user' => $usuario_ingresado, 'pass' => $password_ingresado]);
$user = $stmt->fetch();
```

- En el Firewall Cisco Firepower (WAF): Comandos para verificar que el servicio de inspección HTTP está bloqueando firmas de inyección:

```
# Verificar el estado de la política de intrusiones (IPS/WAF)
show service-policy inspect http
# Ver eventos de bloqueo de inyecciones en tiempo real
show asp drop frame session
```

Paso 2 : Inteligencia de Amenazas Proactiva

Para asegurar que NovaShop no solo reaccione a ataques conocidos, sino que se anticipe a amenazas mundiales, se recomienda integrar Cisco Talos:

- **Filtrado de Reputación:** El Firewall consulta la base de datos de Talos en tiempo real para bloquear IPs de atacantes, botnets y sitios de phishing antes de que lleguen a la aplicación.
- **Verificación de Estado:**

```
# Verificación de redundancia activa
show switch
# Configuración de enlace redundante para el servidor Dell
interface range Te1/0/1, Te2/0/1
channel-group 1 mode active
```

Bloqueo de Movimiento Lateral e Identidad

Tras demostrarse que las credenciales robadas permitían el acceso SSH a otros servidores, se aplicaron los siguientes controles:

- Aislamiento de Tráfico: Configuración de VLANs segmentadas. El servidor de Base de Datos ahora solo acepta conexiones en el puerto 1433 originadas exclusivamente desde la IP del Servidor Web, bloqueando cualquier otro intento interno.
- Protección de Identidad (DAI): Activación de Dynamic ARP Inspection. El switch ahora valida cada paquete ARP contra la base de datos de DHCP Snooping, descartando automáticamente los ataques de suplantación detectados en el laboratorio.

Pasos de Remediación Técnica

Paso 1 :Configuración de VLANs y ACLs en el Switch Catalyst 9500 (ID-01)

Restringimos que solo la IP del servidor web pueda hablar con la base de datos por el puerto 1433.

```
# Crear la lista de acceso extendida
ip access-list extended ACL_PROTECCION_SQL
 permit tcp host 192.168.10.50 host 192.168.110.10 eq 1433
 deny ip any host 192.168.110.10
 permit ip any any
```

```
# Aplicar a la interfaz de la VLAN de servidores
interface Vlan110
 ip access-group ACL_PROTECCION_SQL in
```

Paso 2 : Configuración de Seguridad de Puertos y DAI

Para evitar que el atacante use herramientas como Kali para suplantar identidades.

```
# Configurar DHCP Snooping y DAI en Switches de Acceso (ID-02)
ip dhcp snooping
ip dhcp snooping vlan 10,20,110
ip arp inspection vlan 10,20,110

# Definir el puerto hacia el Core como confiable
interface GigabitEthernet1/0/48
 ip dhcp snooping trust
 ip arp inspection trust
```

Alta Disponibilidad e Infraestructura Crítica

Para corregir el riesgo de paro total evidenciado durante la enumeración de la red:

- Redundancia Activo-Activo: Implementación de StackWise-480 en los Catalyst 9500. Se validó que, al desconectar el switch principal, el tráfico de la aplicación web conmuta al switch de respaldo sin pérdida de sesiones.
- Resiliencia Energética: Integración de PowerChute, permitiendo que el servidor Dell PowerEdge realice un apagado ordenado en caso de fallo crítico de la UPS, protegiendo la integridad de la base de datos SQL.

Pasos de Remediación Técnica

Paso 1 :Configuración de StackWise-480 (Cisco Catalyst 9500)

Unimos dos switches físicos para que funcionen como uno solo con redundancia.

```
# Verificar que los switches se reconocen en el stack
show switch
# Configurar la prioridad para asegurar el orden de failover
switch 1 priority 15
switch 2 priority 14

# Configurar LACP (EtherChannel) para el servidor Dell
interface range GigabitEthernet1/0/1, GigabitEthernet2/0/1
channel-group 1 mode active
description LINK_REDUNDANTE_SERVIDOR_VENTAS
```

Paso 2: Script de Apagado Proactivo (Integración con UPS)

Comando para programar el cierre de la base de datos SQL antes de que la batería se agote.

```
# Script para PowerChute (Windows/SQL Server)
Stop-Service -Name "MSSQLSERVER" -Force
Write-EventLog -LogName Application -Source "UPS_Shutdown" -EventID 100 -Message
```

Conclusión de la Fase de Pentesting

Los ataques simulados permitieron identificar debilidades estructurales que han sido corregidas con éxito. La infraestructura de NovaShop S.A. ha pasado de ser un entorno basado en confianza implícita a un modelo de defensa activa. Con la integración de Cisco Talos para la inteligencia perimetral y el Hardening de Capa 2 para la seguridad interna, la organización cuenta ahora con una postura de seguridad moderna, auditable y alineada con los estándares internacionales.

Recomendaciones de Seguridad Adicionales

Para garantizar que los controles implementados no se degraden y que NovaShop S.A. Mantenga su resiliencia operativa, se establece la siguiente hoja de ruta basada en ciclos de auditoría y mejora continua.

Trazabilidad Inmutable y Gobierno de Datos (Gestión de Logs)

Para asegurar que cualquier intento de intrusión sea registrado sin posibilidad de alteración (Integridad de la evidencia):

- Centralización de Eventos: Se ha configurado la infraestructura (Catalyst, WAF, y alertas de Capa 2 como DAI/DHCP Snooping) para centralizar registros en el Servidor Syslog (192.168.99.50).
- Protocolo de Retención: Se establece un acceso restringido al servidor de logs. Queda estrictamente prohibida la purga de registros antes de los 90 días naturales, asegurando la capacidad de realizar análisis forenses y cumplir con la Ley 8968.

Hardening Físico y Ambiental (Defensa en Profundidad)

La seguridad física es el primer nivel de protección de los activos críticos:

- Control de Acceso al Rack: Sustitución de cerraduras físicas por sistemas biométricos o RFID en el Rack 42U, generando un log digital de cada apertura auditado mensualmente.
- Estabilización Ambiental: Mantenimiento de un umbral térmico de 21°C para proteger la vida útil de los servidores Dell PowerEdge.
- Vigilancia Inteligente: Auditoría mensual de las cámaras Meraki MV, garantizando la integridad del almacenamiento en la nube y la ausencia de puntos ciegos.

Gestión de Vulnerabilidades y Ciclo de Vida (ISO 27001 A.8.8)

Para evitar la exposición accidental de servicios tras mantenimientos de rutina:

- Escaneos Trimestrales (Nmap): Verificación activa de que protocolos inseguros (Telnet/HTTP) permanezcan cerrados y que solo el puerto 443 sea accesible hacia la DMZ.
- Ventanas de Mantenimiento: Actualización mensual programada del IOS-XE de los switches y las firmas de amenazas en el IPS Firepower, asegurando protección contra ataques de día cero.

Pruebas de Continuidad y Recuperación de Desastres (DRP)

La redundancia física de StackWise debe respaldarse con la integridad de la información:

- Simulacro Semestral: Ejecución de cortes de energía controlados para validar que el software PowerChute inicie correctamente el cierre ordenado de la Base de Datos SQL antes de agotar la batería de la UPS APC. Esto garantiza la consistencia de los datos de ventas.

Declaración de Cierre y Certificación Técnica

Con la implementación de los controles técnicos documentados y el seguimiento de estas recomendaciones proactivas, la infraestructura de NovaShop S.A. queda formalmente certificada bajo un modelo de defensa en profundidad. La intervención de este equipo consultor ha permitido transformar una red vulnerable en un entorno resiliente, auditable y seguro, minimizando el riesgo de interrupciones operativas y garantizando la confidencialidad de los activos críticos de la organización.

Firma: 

Maria Mercedes Segura Hernández

Network Security Tester